PFIZER

STRATEGIC ENTERPRISE GITHUB EXPANSION ROADMAP

A 12-Month Plan for Security, Productivity, and Platform Growth

by Modus Create, 2026

www.moduscreate.com

Table of Contents

Purpose of this Document

This document sets out a data-driven baseline of GitHub platform adoption across Pfizer's 23 GitHub organizations, and a phased roadmap for growing four capabilities in a coordinated way: GitHub Advanced Security, CodeQL, GitHub Copilot, and Token-Based Billing governance. It is written for platform, security, and engineering leadership as an input to funding and sequencing decisions.

Every figure in the Current State Baseline section was measured directly through the GitHub API using a purpose-built collection tool, not estimated or extrapolated. The collector, the raw CSVs it produces, and the workflow that runs it are all version-controlled in the same repository referenced throughout this document, which means every number here can be regenerated and checked at any time.

The document treats security coverage, developer productivity, and platform consumption as three views of one expansion effort rather than three separate initiatives. This is a deliberate framing choice, not a simplification. Turning on security scanning for a repository, giving a developer a Copilot seat, and consuming platform minutes are three sides of the same action, and a roadmap that plans them separately tends to produce three uncoordinated conversations instead of one coherent one.

Executive Summary

Across 23 organizations and 16,989 active repositories, each of the four capabilities in scope for this roadmap is, today, a single organization proof of concept that has already worked at real scale. The opportunity in front of Pfizer is not to invent something new. It is to take patterns that are already succeeding in one part of the enterprise and extend them, deliberately and in sequence, to the rest of it.

All coverage figures are per-organization, collected via the GitHub API across all 23 organizations on 4 August 2026; the full per-org breakdown is in Appendix A.

16,989	8.3%	987	3,560	436k+	$18,458
Active Repositories	GHAS Coverage	CodeQL Active Repos	Copilot Seats (63% active)	Open Security Alerts	Spend per Period

Five things stand out in the baseline and shape everything that follows.

GHAS already works in one organization. pfizer-eps runs GHAS with code scanning across all 1,359 of its repositories, showing the configuration works at scale (1,300+ repos) in Pfizer's environment. Fourteen of the other 22 organizations have zero GHAS repositories. The question for the rest of the enterprise is no longer whether it works but when to roll it out.

CodeQL is trailing behind licensing that Pfizer has already paid for. Across the organizations where GHAS is enabled, 987 repositories, or 70 percent, are actively scanning with CodeQL and have already surfaced 10,915 open code scanning findings. The other 30 percent of GHAS licensed repositories are not scanning at all. Turning scanning on for those repositories requires no new tooling licence, though it does consume Actions minutes and, where it extends GHAS to new repositories, adds to committer-based GHAS cost.

Copilot is currently deployed mainly through pfizer-devex (3,551 of 3,560 seats). This concentration is by design: per GitHub's guidance (meeting of 05/08/2026), Copilot deployment is moving to enterprise-level management as the default path. The relevant measure is enterprise-wide utilization, not per-org expansion.

Of those seats, 37% were inactive last cycle. Since each seat includes a token allowance before usage-based charges apply, inactive seats mean unused licence value while overall token consumption is already over budget.

Platform consumption is dominated by Copilot. Copilot spend was approximately $250,000 in July 2026 and is projected to reach roughly $400,000 by September/October 2026, partly because a discount is ending.

There is a large amount of unmanaged risk and repository hygiene debt sitting underneath all of this. Open Dependabot alerts across the enterprise total 423,294, and that figure is a floor, not a ceiling, because two organizations hit the API's 100,000 alert counting cap and their true totals are higher. Separately, 39 percent of all repositories in the enterprise, 11,022 of them, are archived. Until that archived population is reconciled, it inflates both the risk picture and any licensing calculation based on repository count.

These findings connect: enabling GHAS produces CodeQL results (security), Copilot adoption affects developer output (productivity), and both drive platform consumption (cost). The roadmap tracks all three on one baseline.

Current State Baseline

Every figure in this section is the enterprise-wide total across all 23 organizations unless a specific organization is named, and every figure was pulled directly from the GitHub API, not estimated. The full per-org table is in Appendix A

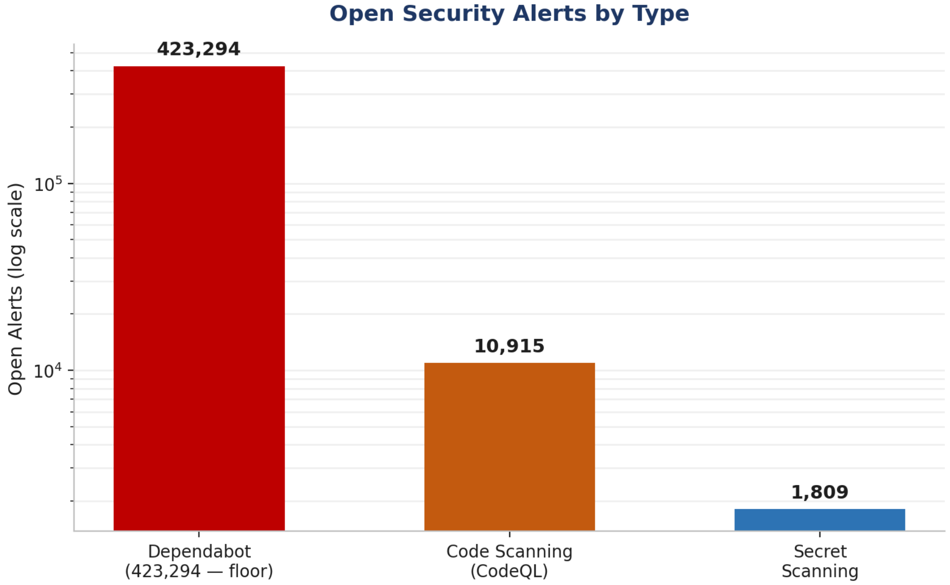
Security Posture

Secret Scanning and its push protection companion feature are effectively universal across the enterprise. Both are active on all 16,989 active repositories. Dependabot security updates are active on 16,906 repositories, or 99.5% of total repositories. The real gap sits with GHAS itself, the licensed Code Scanning product, which is enabled on 1,411 repositories, 8.3% of the active estate.

Control	Repositories Enabled	Coverage
Secret scanning	16,989	100% of active repos
Secret scanning push protection	16,989	100%
Dependabot security updates	16,906	99.5%
Code Scanning enabled licensed	1,411	8.3%
of which private	875	
of which internal	536	

The open alert inventory shows where the untriaged risk actually sits.

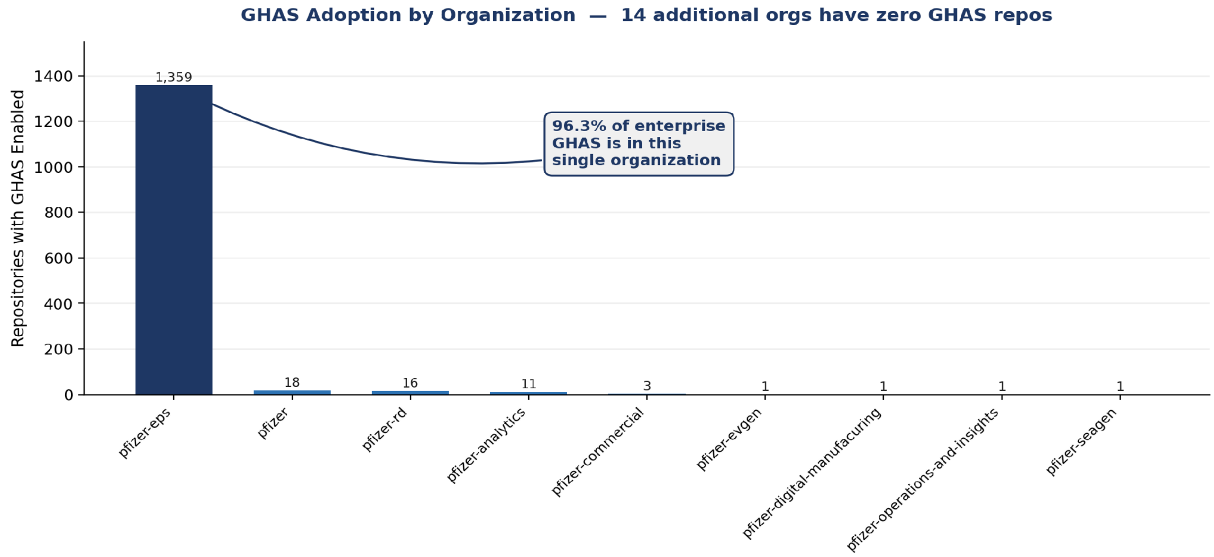
Alert Type	Open Count	Note
Dependabot	423,294	Floor. pfizer and pfizer-business-services each hit the 100,000 per organization counting cap, so the true enterprise figure is higher.
Code scanning (CodeQL)	10,915	Real findings awaiting triage across the 987 actively scanning repositories.
Secret scanning	1,809	



Open security alerts by type, shown on a log scale because of the spread between categories.

GHAS adoption is heavily concentrated in a single organization.

Organization	Code Scanning enabled	Share of Enterprise
pfizer-eps	1,359	96.3%
pfizer	18	1.3%
pfizer-rd	16	1.1%
pfizer-analytics	11	0.8%
All other organizations (19 combined)	7	0.5%

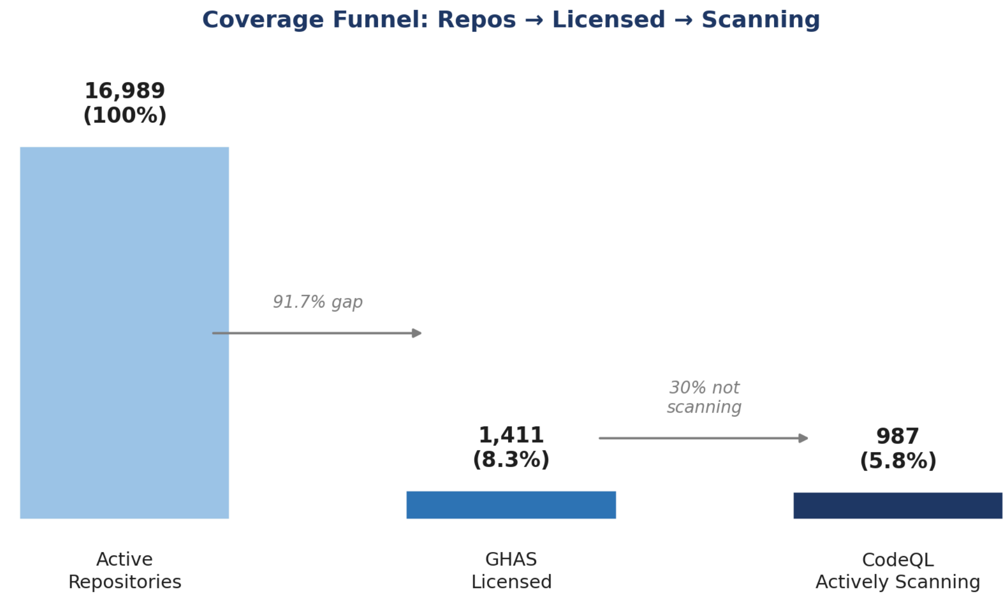


GHAS enabled repositories per organization, ordered from highest to lowest.

Development Platform

The development platform shows that roughly 40% of all repos are archived. Of active repos, only 987 have CodeQL currently actively scanning. However, the implementation of SonarQube accounts for the remaining Code Scanning coverage.

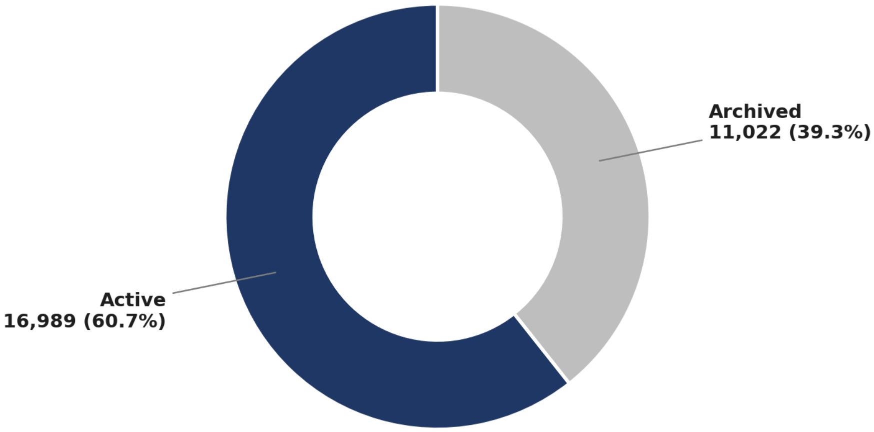
Metric	Value
Active repositories	16,989
Archived repositories	11,022 (39.3% of all repositories)
Private / Internal / Public split	14,723 / 2,266 / 0
CodeQL actively scanning	987 (5.8% of active repos, 70% of repos with Code Scanning enabled)
Actions minutes used this period	99,883 (64,987 paid)



The 70 percent figure is the one worth sitting with. Roughly 30 percent of repositories that Pfizer is already paying GHAS licensing for are not scanning with CodeQL at all. That gap requires no new tooling licence, though it does consume Actions minutes, and as with any GHAS expansion where it activates code scanning on repositories not previously scanned, it can add to committer-based GHAS cost. It is treated as the first move in the phased roadmap because the licence is already in place, not because it is free.

Pfizer currently runs SonarQube. A July proof-of-concept on 3 repositories where both tools were active found CodeQL surfaced 90 open findings, all security-relevant (100%), versus SonarQube's 4,646 open findings of which 181 (3.9%) were security-related. CodeQL needs no dedicated infrastructure and maps every finding to CWE. (PoC caveats: 3-repo sample, directional; SonarQube also covers code-quality, which CodeQL does not.

Repository Hygiene: Active vs Archived

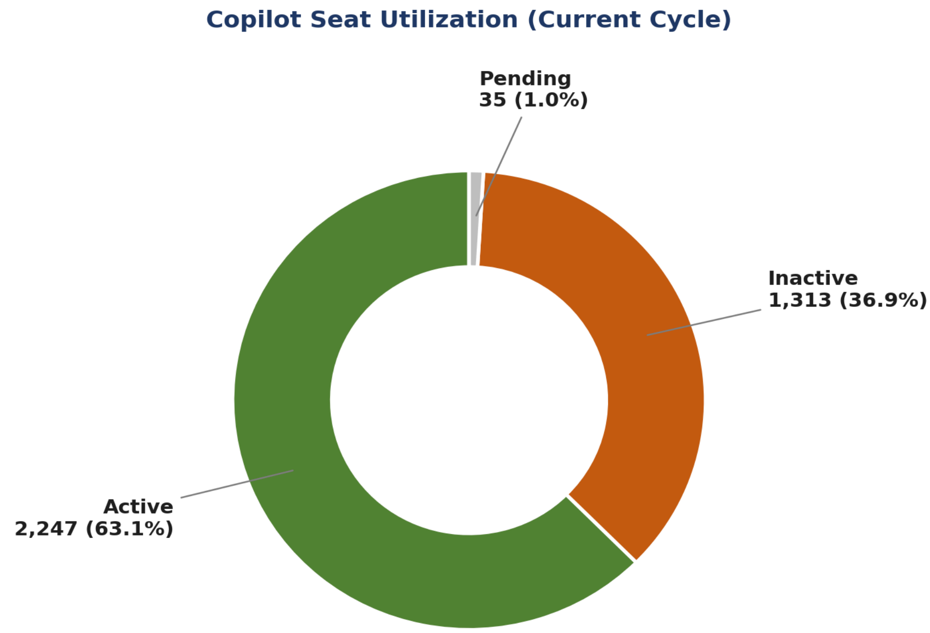


39.3% of the repository estate is archived. Until this is reconciled it inflates both the risk baseline and any licensing calculation based on repository count.

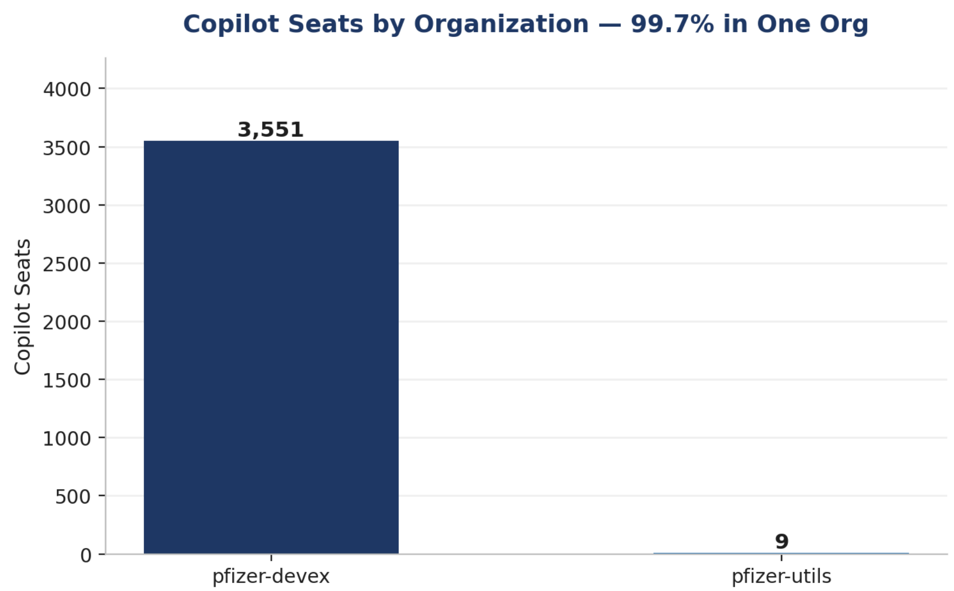
Productive Tooling

Copilot is a genuinely funded, actively used productivity capability at Pfizer today. It is also heavily concentrated and, right now, underused relative to what has already been paid for.

Metric	Value
Total seats	3,560
Active this billing cycle	2,247 (63.1%)
Inactive this billing cycle	1,313 (36.9%)
Pending	35
Seats in pfizer-devex	3,551 (99.7% of all seats)
Seats in pfizer-utils	9



The 1,313 inactive seats are, on their own, the single largest efficiency opportunity anywhere in this roadmap. Reclaiming and redeploying even a portion of them could fund a second organization's worth of Copilot adoption without a single dollar of new spend.



Copilot seats by organization. 99.7% sit in pfizer-devex, mirroring the same concentration pattern seen in GHAS adoption.

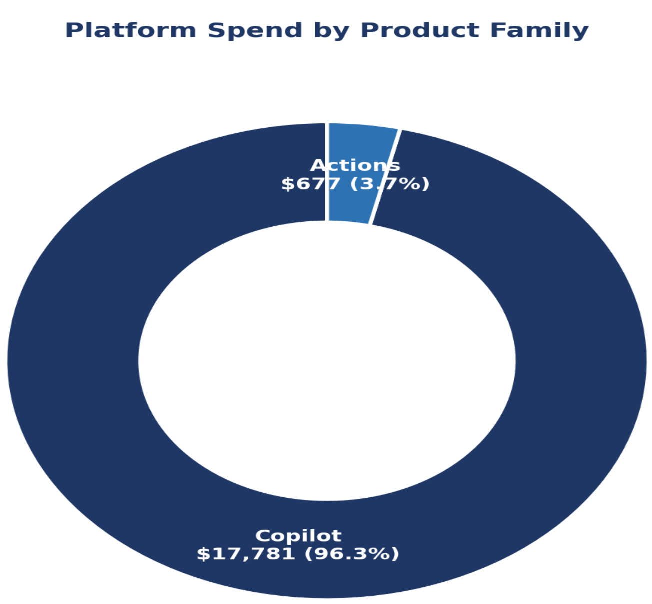
Platform Consumption

Token-based consumption is growing rapidly and is dominated by Copilot; projected Copilot spend for September/October 2026 is approximately $400,000. Consumption governance already exists at Pfizer, and the priority is addressing its current shortcomings, not creating new structures.

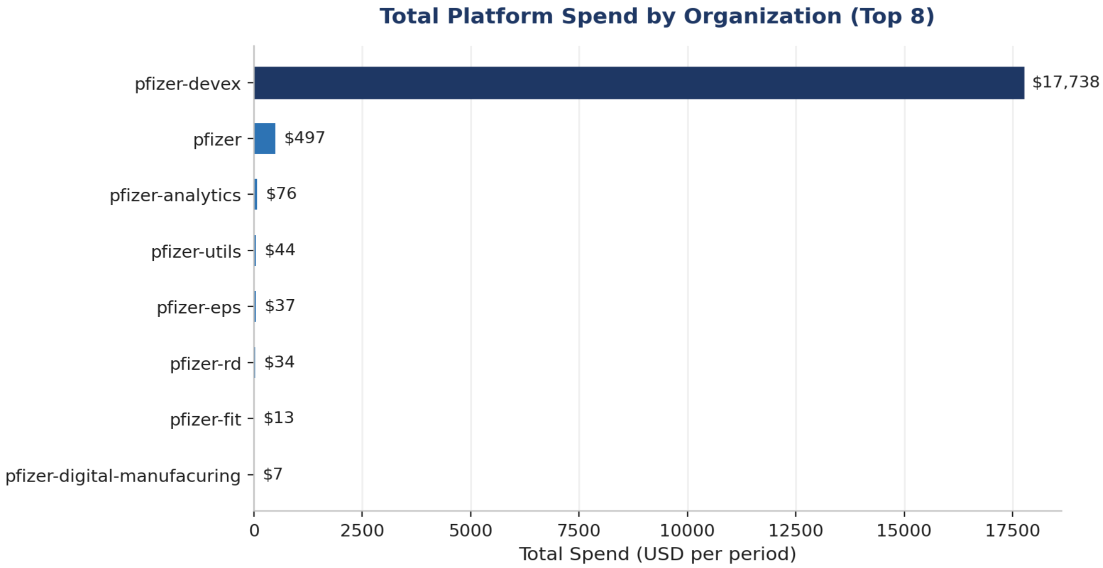
Copilot's spending was approximately $250,000 in July 2026. A discount is ending, which is a material driver of the projected increase. Actions and storage costs remain modest by comparison but will grow as GHAS and CodeQL coverage expand.

Product Family	Spend per Period	Share
Copilot	$17,781.48	96.3%
Actions	$676.88	3.7%
Packages	$0.00	0% (usage measured in GB-hours)
Storage	$0.00	0% (usage measured in GB-hours)
Total	$18,458.36	100%

Non-billed consumption is tracked separately and totals 2,258 gigabyte hours of package storage and 293,281 gigabyte hours of shared storage, which covers Actions artifacts and Git LFS.



Spend by organization follows the same concentration pattern seen throughout this baseline. pfizer-devex accounts for 17,738 dollars, almost entirely Copilot. pfizer accounts for 497 dollars, mostly Actions. Every other organization sits under 80 dollars.



Cross-Cutting View

The single most useful chart in this baseline is the one that puts all four capabilities side by side against all 23 organizations. It makes the expansion targets select themselves.

CI/CD Pipeline Security

A scan of every GitHub Actions workflow across all 23 organizations found 51,090 security issues in CI/CD pipelines (43,448 critical, 7,194 high, 448 medium) across 9,113 repositories. The most common issues are missing workflow permissions (17,445), unvetted action publishers (12,533), and actions pinned to a tag rather than a commit SHA (12,097).

Secrets Management

Secret scanning and push protection are enabled on all 16,989 active repositories (100%), with 1,809 open secret-scanning alerts. Separately, the pipeline scan found approximately 4,572 hardcoded secrets and keys committed directly in workflow files (3,210 AWS secrets, 1,362 RSA keys), indicating credentials-in-code remains an active risk to remediate.

Strategic Vision

Four principles translate the baseline into a direction. Each one maps to a specific pillar in the baseline above and to something that can actually be measured, not just asserted.

Security by Default

Code security should be the default posture for internal and private repositories, not something a team opts into. pfizer-eps already proves this is achievable at Pfizer's scale. The vision is GHAS and CodeQL enabled by default across the largest organizations, with alert triage run as a managed workload against a stated service level rather than an open ended backlog.

Developer Productivity Uplift

Copilot should be deployed where it demonstrably changes how much developers get done, and judged by engagement rather than by how many seats have been handed out. The vision is that every licensed seat is an active seat, that expansion decisions are made from evidence rather than assumption, and that productivity gains are reported next to cost rather than separately from it.

Supply Chain Discipline

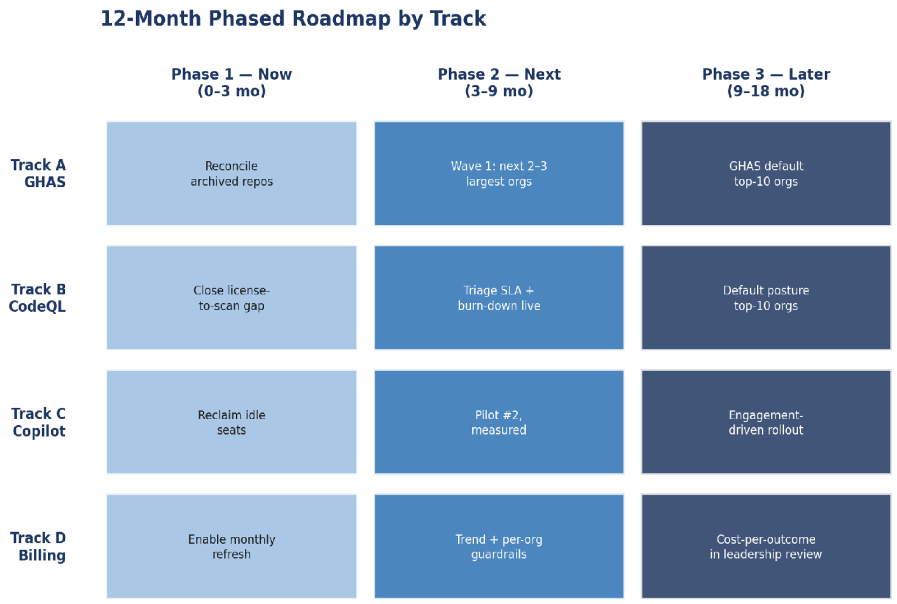
Dependency and workflow integrity are treated as first-class concerns, not an afterthought. This covers Dependabot, where 423,000 plus open alerts need to be worked down, CodeQL findings, and the workflow security controls, such as action pinning and least privilege permissions. The vision is a shrinking, actively governed alert surface and a vetted, pinned action allowlist across the enterprise. Additional areas the roadmap addresses: release-process maturity (many teams lack a defined release process), credentials still present in code, and secret-management practices.

Cost Aware Growth

Consumption growth is expected, and it is welcome, provided it stays visible, is attributed to something, and tied to an outcome. The vision is that every wave of expansion carries a predicted consumption delta, that actuals get tracked against that prediction every month, and that leadership sees cost per outcome, dollars per GHAS-covered repository, and dollars per active Copilot user, rather than just a total that goes up.

Phased Roadmap

The twelve-month roadmap runs across three phases. Phase 0, the baseline itself, is already complete and is what this document reports on. Phases 1 through 3 are sequenced so that the moves costing nothing new happen first, and nothing scales up without being measured first.



Phase 0: Baseline Established (Complete)

A reproducible, per organization, enterprise-wide baseline now exists for all four pillars, captured through a scheduled GitHub Actions workflow. This document is the baseline's output.

Phase 1: Now, Months 0 to 3

The theme of this phase is tidying up what already exists before spending anything new.

- **Track B:** Close the CodeQL license to scan gap. Roughly 30 percent of GHAS repositories are not scanning yet, and this costs nothing to fix.
- **Track C:** Reclaim the 1,313 inactive Copilot seats through a monthly active versus licensed review.
- **Track A and hygiene:** reconcile and confirm the 11,022 archived repositories so that every downstream metric reflects live risk rather than dead weight.
- **Track D:** turn on the scheduled monthly refresh of this baseline.

- **Enabler:** unblock Copilot engagement telemetry, which currently depends on allow listing a specific host on the self hosted runner proxy.

Phase 2: Next, Months 3 to 9

The theme of this phase is expanding the pillars that Phase 1 already proved out.

- **Track A:** first GHAS wave, covering the next two to three largest untapped organizations, pfizer, pfizer-rd, and pfizer-digital-manufacuring, using the pfizer-eps rollout as the runbook.
- **Track B:** CodeQL follows each GHAS wave as it lands. Triage service level and findings burn down go live alongside it.
- **Track C:** second Copilot pilot in one additional high developer organization, with productivity measured against a defined baseline from day one.
- **Track D:** first monthly spend trend and per organization guardrails published to the governance forum.

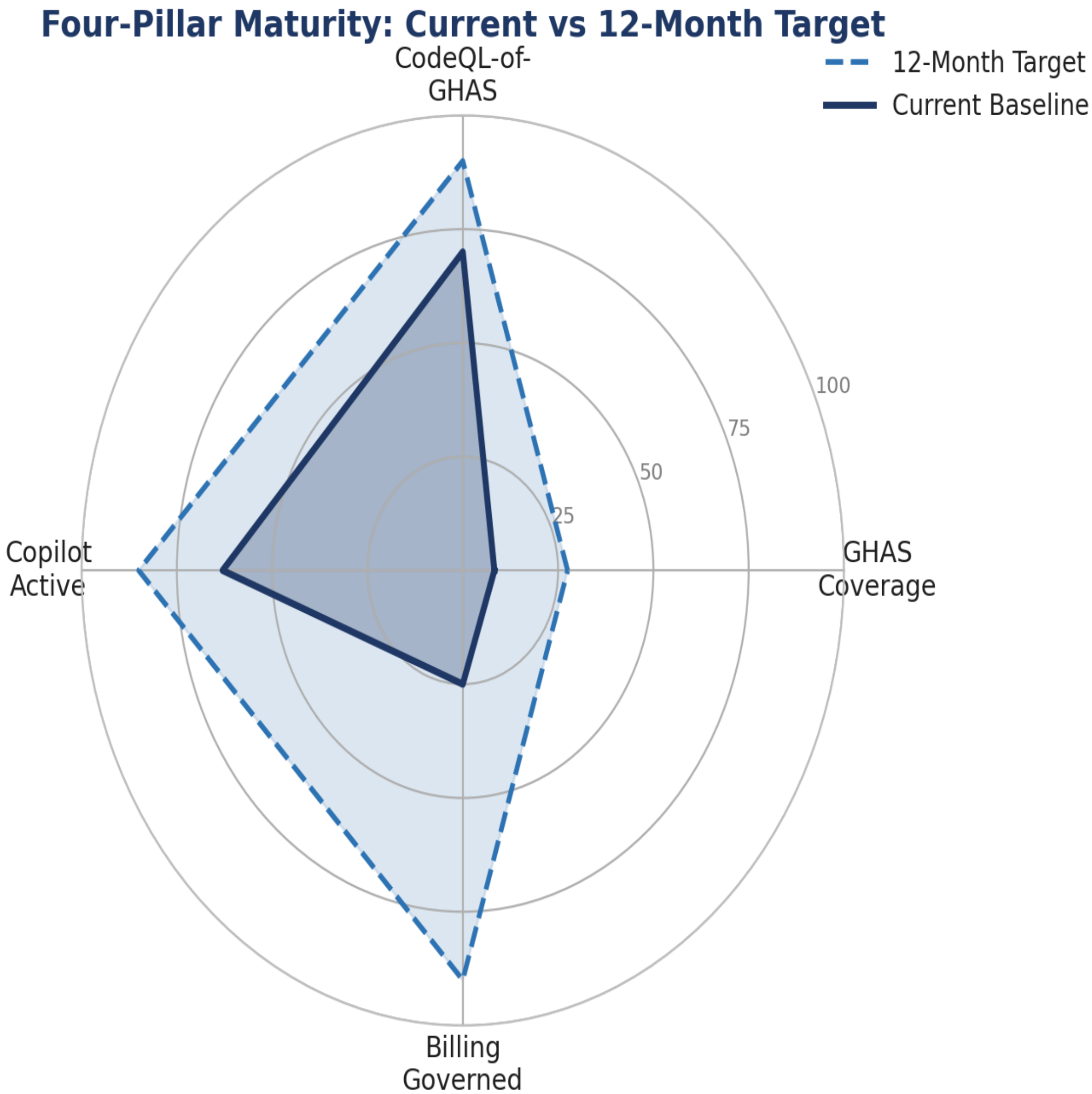
Phase 3: Later, Months 9 to 18

The theme of this phase is making the current exception, GHAS and CodeQL running well, the default rather than the exception.

- **Track A and B:** GHAS and CodeQL become the default posture for internal and private repositories across the ten largest organizations.
- **Track C:** Copilot rollout decisions are driven by measured engagement, not by how many seats are assigned.
- **Track D:** cost per outcome reporting is a standing part of the leadership review, and consumption growth is explicitly tied back to the security and productivity gains that caused it.

Measurement Framework

This baseline is itself the measuring instrument. Every track already has a captured headline number, so tracking progress from here is simply a matter of running the same collection again and comparing results. Re-running the workflow monthly regenerates every figure in this document with no manual effort involved.



Current baseline against the twelve month target on all four pillars. GHAS coverage has the furthest distance to travel of the four.

Metric Domains and Ownership

Track	Headline Metric	Baseline (Aug 4, 2026)	Twelve Month Target
A, GHAS	Percent of active repos with code security	8.3%	25 to 30%
B, CodeQL	CodeQL active as % of GHAS licensed	70%	90% or higher
B, CodeQL	Open code scanning alerts	10,915	Managed burn down
C, Copilot	Active as % of licensed seats	63%	85% or higher
C, Copilot	Engaged users	Not available	Establish and track
D, Billing	Total spend and cost per outcome	$250k (July 2026)	Governed growth
Hygiene	Archived repository ratio	39.3%	Reconciled and reduced
Supply chain	Open Dependabot alerts	423,294 (floor)	Downward trend

This baseline is regenerated monthly through a scheduled workflow, and each metric in the table above has a named owner reviewing it.

Investment and Cost Dependencies

Expansion carries real cost, but the cost is sequenced deliberately, and Phase 1 is designed to be largely self-funding rather than requiring a new budget up front.

Cost Drivers by Track

- **Track A, GHAS:** GHAS is typically billed by unique active committer rather than by repository, so enabling more organizations raises the committer count that licensing is calculated against. The Phase 1 archived repository reconciliation directly reduces this. The enterprise-level committer count is not available from the organization-scoped API and needs confirmation from an enterprise administrator before Phase 2 waves are sized.
- **Track B, CodeQL:** there is no incremental license cost beyond GHAS itself, since CodeQL is included. The real cost is Actions minutes consumed while scans run, which is modest today at 99,883 minutes per period but will grow in proportion to coverage.
- **Track C, Copilot:** cost here is per seat. The 1,313 currently inactive seats are the primary lever for funding expansion, since reclaiming and redeploying them offsets new adoption before any net new seats need to be purchased.
- **Track D, Billing:** cost is negligible. The monthly refresh runs on existing self-hosted infrastructure.

Self-Funding Logic

Phase 1 is explicitly designed to require no new spend. Turning on CodeQL scanning that is already paid for, reclaiming idle Copilot seats, and reconciling archived repositories all cost engineering time rather than budget. Phases 2 and 3 should each carry a predicted consumption delta under Track D, and where possible should be partly funded by what Phase 1 reclaims rather than treated as entirely new spend.

Near Zero Cost Dependencies

- Allow listing the Copilot engagement report host on the self hosted runner proxy, which unblocks the Track C engagement metric.
- Enterprise administrator confirmation of GHAS committer billing figures, which sizes Track A accurately before its waves are planned.

Risk and Dependencies

Programme Risks

Risk	Impact	Mitigation
Turning on CodeQL or GHAS at scale surfaces a large volume of findings at once	Triage capacity gets overwhelmed and teams disengage from the process	Phase in by wave rather than all at once, with a stated triage service level and a burn down plan agreed before each wave starts
Idle Copilot spend continues unaddressed	37 percent of seats stay unused, and that makes the case for further expansion harder to justify	Monthly active versus licensed review, with reclamation built into Phase 1
Archived repositories are not reconciled	Risk figures and licensing estimates stay inflated by dead repositories	Reconcile the 11,022 archived repositories as a Phase 1 activity
Consumption grows faster than governance can keep up	A cost surprise reaches leadership instead of being caught early	Enable the monthly refresh and per organization guardrails before Phase 2 expansion begins
Rollout proceeds without a documented runbook	Onboarding new organizations is slow and inconsistent between teams	Document the pfizer-eps rollout as the reference implementation before Phase 2 starts

Why Some Figures Are Floors or Not Available

A few figures in this baseline are stated as floors or as not available rather than as precise numbers, and it is worth being direct about why, since none of them are guesses standing in for missing data.

- **Dependabot alerts, 423,294, is a floor.** pfizer and pfizer-business-services each hit the API's 100,000 alert per organization counting cap, so the true enterprise total is higher than what is reported here.
- **CodeQL coverage, 987, is a lower bound.** It counts repositories with at least one open code scanning alert. A repository that is scanning cleanly with zero open alerts is not counted, since the per-repository code scanning endpoint commonly returns a permission error rather than a clean result in that case.
- **Copilot engagement is not available.** The inline engagement metrics endpoint GitHub previously offered has been retired. The replacement reporting endpoint returns a

download link to a GitHub hosted report host, and that host is currently blocked by the self hosted runner's proxy. Allow listing that host is what unblocks this.

- **GHAS active committers is not available.** The organization scoped API endpoint for this returns an error, because committer billing for GHAS is calculated at the enterprise level rather than the organization level. Getting a precise figure requires enterprise administrator access.
- **Storage figures are reported in gigabyte hours,** which is the unit GitHub's usage API returns, rather than as a point in time gigabyte snapshot.

None of these limitations block the roadmap. Each one is either a scoped, known enhancement to the collector or an external dependency that is already named and assigned in this document.

External Dependencies

This roadmap depends on continued execution of the existing GHAS Governance and Rollout Outline as its operating framework, on continued progress of the RAM integration workstream to unblock the Track A wave sequencing, and on the EMU readiness workstream reaching its Phase 3 handover. A delay in any of these affects the corresponding track directly.

What This Document Does Not Cover

These boundaries are stated explicitly so nothing is left to be inferred.

- **Remediation of individual alerts.** This is a posture baseline and a roadmap, not a triage plan for the 423,000 plus open Dependabot findings or the 10,915 open code scanning findings.
- **Copilot engagement depth.** Active and engaged user metrics are not available until the runner proxy allow list change is made. Only seat counts and spend are covered here.
- **Enterprise level committer billing.** GHAS active committer counts are not available at the organization level. Precise GHAS license sizing requires enterprise administrator data that this collector does not have access to.
- **Public repository posture.** Pfizer's EMU environment has no public repositories, so this is out of scope by definition rather than by omission.
- **Trend data beyond this single snapshot.** Every figure in this document is as of August 4, 2026. Trends over time require the monthly refresh to accumulate history.
- **Vendor pricing and contract terms.** Cost drivers are described qualitatively above. Commercial figures and contract specifics are outside what this roadmap covers.

Per-organization baseline, from the GitHub API, Code Scanning enabled = repos with the Advanced Security code-scanning switch ON (1,411). Code Scanning w/ alerts = of those, repos currently producing CodeQL alerts (987). Secret scanning and Dependabot are separate switches.

Organization	Active repos	Code Scanning enabled	Code Scanning alerts	Secret scanning	Dependabot updates	Open Dependabot alerts	Copilot seats
pfizer	6,692	18	17	6,692	6,692	100,000*	0
pfizer-rd	3,191	16	13	3,191	3,191	63,140	0
pfizer-eps	1,359	1,359	944	1,359	1,276	14,179	0
pfizer-analytics	1,146	11	7	1,146	1,146	41,130	0
pfizer-digital-manufacuring	998	1	1	998	998	34,986	0
pfizer-fit	863	0	0	863	863	17,486	0
pfizer-business-services	607	0	0	607	607	100,000*	0
pfizer-esc	550	0	0	550	550	2,366	0
pfizer-seagen	253	1	1	253	253	14,310	0
pfizer-operations-and-insights	236	1	1	236	236	5,555	0
pfizer-commercial	194	3	3	194	194	4,198	0
pfizer-evgen	160	1	0	160	160	573	0
pfizer-marm	157	0	0	157	157	4,940	0
pfizer-digital-supply	152	0	0	152	152	1,717	0
pfizer-oneweb	127	0	0	127	127	960	0
pfizer-finance	104	0	0	104	104	3,491	0
pfizer-eps-dpp	64	0	0	64	64	2,049	0
pfizer-clinical-supply	53	0	0	53	53	6,929	0
pfizer-devex	37	0	0	37	37	220	3,551
pfizer-pic	25	0	0	25	25	4,923	0
pfizer-ld	13	0	0	13	13	128	0

Organization	Active repos	Code Scanning enabled	Code Scanning alerts	Secret scanning	Dependabot updates	Open Dependabot alerts	Copilot seats
pfizer-compliance	4	0	0	4	4	14	0
pfizer-utils	4	0	0	4	4	0	9
TOTAL	16,989	1,411	987	16,989	16,906	423,294	3,560

* capped at 100,000 by the API's counting limit, the true figure is higher.